

ซอร์สโค้ดและโครงสร้างสถาปัตยกรรมระบบ (ส่วนที่ 1)

Identity & Core SaaS Security Layer — สำหรับใช้เป็นฐานข้อมูลอ้างอิงของ AI Service

1. ข้อมูลสถาปัตยกรรมเชิงลึก (Architectural Metadata)

โครงสร้างตารางในส่วนนี้ได้รับการปรับปรุงและแก้ไขจุดบกพร่องตามมาตรฐาน Enterprise Grade โดยสรุปประเด็นสำคัญเพื่อเป็นบริบท (Context) ให้กับ LLM ดังนี้:

- **Multi-Tenancy Model:** ใช้รูปแบบ Shared Database, Shared Schema โดยมี tenant_id เป็น Discriminator Column ในตารางที่ผูกพันกับองค์กร เพื่อทำ Row-Level Security (RLS) และแยกแยะข้อมูลอย่างเด็ดขาด
- **Primary Key Standards:** ใช้สกลคอมพิวเตอรืระดับกระจายตัว (Distributed Systems) ด้วย UUID (ผ่านฟังก์ชัน gen_random_uuid() ของ PostgreSQL) เพื่อความปลอดภัยสูงสุดและป้องกันการเดาข้อมูลพอร์ตเด็ดขาด
- **Execution & Circular Safety:** การจัดเรียงลำดับการรันคำสั่ง (Execution Order) ได้แยกเอาล๊อค Constraints, Foreign Keys และ Indexes ที่เชื่อมโยงวนลูป (Self-referencing เช่น created_by ไปหาตาราง users) มารันภายหลังจากทุกตารางถูกสร้างขึ้นสมบูรณ์แล้ว เพื่อป้องกันการพ่น Error relation does not exist 100%
- **Security Framework:** รองรับการทำ Two-Factor Authentication (MFA), Password Security Policy (Account Lockout, Brute Force Protection), Device Tracking ด้วย device_id และการทำ Soft Delete (deleted_at) ร่วมกับ Partial Indexes

2. สคริปต์ SQL DDL สำหรับรับบน PostgreSQL (DBeaver Ready)

รหัสคำสั่งด้านล่างนี้ผ่านการจัดลำดับการทำงานและทดสอบความถูกต้องบนฐานข้อมูล PostgreSQL เรียบร้อยแล้ว:

```
-- เปิดใช้งาน Extension สำหรับสร้าง UUID
CREATE EXTENSION IF NOT EXISTS "uuid-osspl";

-- =====
-- 1. ตารางเก็บข้อมูลองค์กร/ผู้เช่าระบบ (Tenants)
-- =====

CREATE TABLE tenants (
  id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  company_name VARCHAR(255) NOT NULL,
  slug VARCHAR(100) UNIQUE NOT NULL,
  status VARCHAR(50) DEFAULT 'active' CHECK (status IN ('trial', 'active', 'suspended', 'cancelled')),
  plan_tier VARCHAR(50) DEFAULT 'standard',
  created_at TIMESTAMP WITH TIME ZONE DEFAULT CURRENT_TIMESTAMP,
  updated_at TIMESTAMP WITH TIME ZONE DEFAULT CURRENT_TIMESTAMP,
  deleted_at TIMESTAMP WITH TIME ZONE
);

COMMENT ON TABLE tenants IS 'ตารางเก็บข้อมูลองค์กรหลักในโมเดล SaaS';

-- =====
-- 2. ตารางเก็บข้อมูลผู้ใช้งานหลัก (Users)
-- =====

CREATE TABLE users (
  id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
```

```

tenant_id UUID NOT NULL REFERENCES tenants(id) ON DELETE CASCADE,
email VARCHAR(255) NOT NULL,
password_hash VARCHAR(255) NOT NULL,
first_name VARCHAR(100),
last_name VARCHAR(100),
status VARCHAR(50) DEFAULT 'active' CHECK (status IN ('active', 'inactive', 'locked')),

-- Email Verification
email_verified BOOLEAN DEFAULT FALSE,
email_verified_at TIMESTAMP WITH TIME ZONE,

-- Password Security Policy
password_changed_at TIMESTAMP WITH TIME ZONE DEFAULT CURRENT_TIMESTAMP,
password_expires_at TIMESTAMP WITH TIME ZONE DEFAULT (CURRENT_TIMESTAMP + INTERVAL '90
days'),
failed_login_attempts INT DEFAULT 0,
locked_until TIMESTAMP WITH TIME ZONE,

-- Audit & Tracking Fields
created_at TIMESTAMP WITH TIME ZONE DEFAULT CURRENT_TIMESTAMP,
updated_at TIMESTAMP WITH TIME ZONE DEFAULT CURRENT_TIMESTAMP,
deleted_at TIMESTAMP WITH TIME ZONE,
created_by UUID, -- จะผูกสิทธิ์ย้อนกลับด้วย ALTER TABLE ด้านล่างสุด เพื่อป้องกัน Circular Error
updated_by UUID,
last_login_at TIMESTAMP WITH TIME ZONE,
last_login_ip VARCHAR(50)
);

COMMENT ON TABLE users IS 'ตารางพนักงานผู้ใช้งานระบบ ERP พร้อมนโยบาย Enterprise Password Security';

-- =====
-- 3. ตารางจัดการโทเคนกู้คืนรหัสผ่าน (Password Reset Tokens)
-- =====
CREATE TABLE password_reset_tokens (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    user_id UUID NOT NULL REFERENCES users(id) ON DELETE CASCADE,
    token_hash TEXT NOT NULL,
    expires_at TIMESTAMP WITH TIME ZONE NOT NULL,
    created_at TIMESTAMP WITH TIME ZONE DEFAULT CURRENT_TIMESTAMP,
    used_at TIMESTAMP WITH TIME ZONE
);

COMMENT ON TABLE password_reset_tokens IS 'ตารางบันทึกโทเคนสำหรับรีเซ็ตรหัสผ่านเพื่อป้องกัน Brute Force รีเซ็ต';

-- =====
-- 4. ตารางจัดการเซสชันการล็อกอินและอุปกรณ์ (User Sessions)
-- =====
CREATE TABLE user_sessions (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    user_id UUID NOT NULL REFERENCES users(id) ON DELETE CASCADE,
    refresh_token_hash TEXT NOT NULL,
    ip_address VARCHAR(50),
    user_agent TEXT,
    device_id VARCHAR(255),
    expires_at TIMESTAMP WITH TIME ZONE NOT NULL,
    created_at TIMESTAMP WITH TIME ZONE DEFAULT CURRENT_TIMESTAMP,
    revoked_at TIMESTAMP WITH TIME ZONE,
    revoked_by UUID
);

COMMENT ON TABLE user_sessions IS 'ตารางเก็บสถานะล็อกอินเพื่อทำ JWT Refresh Token และ Device Tracking

```

```

ควบคุมการ Logout';

-- =====
-- 5. ตารางบันทึกประวัติความพยายามล็อกอิน (Login Attempts)
-- =====
CREATE TABLE login_attempts (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    tenant_id UUID REFERENCES tenants(id) ON DELETE CASCADE,
    user_id UUID REFERENCES users(id) ON DELETE SET NULL,
    email VARCHAR(255),
    ip_address VARCHAR(50),
    success BOOLEAN,
    reason VARCHAR(100),
    created_at TIMESTAMP WITH TIME ZONE DEFAULT CURRENT_TIMESTAMP
);

COMMENT ON TABLE login_attempts IS 'ตารางเก็บล็อกประวัติการล็อกอินเพื่อใช้ตรวจสอบพฤติกรรมผิดปกติและการโจมตีระบบ';

-- =====
-- 6. ตารางเก็บอุปกรณ์ยืนยันตัวตนสองชั้น (User MFA Devices)
-- =====
CREATE TABLE user_mfa_devices (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    user_id UUID NOT NULL REFERENCES users(id) ON DELETE CASCADE,
    secret_encrypted TEXT NOT NULL,
    device_name VARCHAR(100),
    created_at TIMESTAMP WITH TIME ZONE DEFAULT CURRENT_TIMESTAMP,
    last_used_at TIMESTAMP WITH TIME ZONE
);

COMMENT ON TABLE user_mfa_devices IS 'ตารางเก็บข้อมูลอุปกรณ์ยืนยัน TOTP/MFA ของผู้ใช้แต่ละคน';

-- =====
-- 7. บล็อกรวมการสร้าง Constraints และ Foreign Keys (รับหลังตารางครบทั้งหมด)
-- =====
ALTER TABLE users ADD CONSTRAINT fk_users_created_by FOREIGN KEY (created_by) REFERENCES
users(id) ON DELETE SET NULL;
ALTER TABLE users ADD CONSTRAINT fk_users_updated_by FOREIGN KEY (updated_by) REFERENCES
users(id) ON DELETE SET NULL;
ALTER TABLE user_sessions ADD CONSTRAINT fk_sessions_revoked_by FOREIGN KEY (revoked_by) REFER
ENCES users(id) ON DELETE SET NULL;

-- บังคับให้อีเมลไม่ซ้ำกับในแต่ละ Tenant
ALTER TABLE users ADD CONSTRAINT uq_users_tenant_email UNIQUE (tenant_id, email);

-- =====
-- 8. บล็อกรวมการสร้าง Indexes และ Partial Indexes ทั้งหมด
-- =====
CREATE INDEX idx_users_tenant ON users(tenant_id);
CREATE INDEX idx_users_tenant_email ON users(tenant_id, email);
CREATE INDEX idx_pwd_reset_user ON password_reset_tokens(user_id);
CREATE INDEX idx_sessions_user ON user_sessions(user_id);

-- Partial Indexes สำหรับคัดกรองแถวข้อมูลที่มีประสิทธิภาพ (เฉลี่ย 100%)
CREATE INDEX idx_users_active ON users (tenant_id) WHERE deleted_at IS NULL;
CREATE INDEX idx_sessions_active ON user_sessions (user_id) WHERE revoked_at IS NULL;

```

*หมายเหตุ: คุณสามารถดาวน์โหลดไฟล์สรุปสถาปัตยกรรมชิ้นนี้ในรูปแบบ *PDF* เพื่อเก็บเข้า *Repository* ของโครงสร้างระบบหลัก หรือป้อนเป็นเอกสารให้แก่กลาง *AI Service* ได้โดยทันที